

Actividad 1 Hacker Women.	
Nombre	Yorbelys Ordonez.
E-mail	yorbelysordonez7@gmail.com
Actividad 1	Hacker Women council - Ethical Hacking.
Caso	Aurora Market.

Analisis y Planificacion del Pentest (Caso Aurora Market)

Objetivo del Pentest.

1. Identificar posibles vulnerabilidades de seguridad en la Aplicación Web de Aurora Market que pueden ser aprovechadas por el atacante y comprometer la confidencialidad, Integridad o disponibilidad de la información.
2. Evaluar el Nivel de Riesgo de las Vulnerabilidades identificadas, considerando la probabilidad de Explotación y el impacto que podrían generar sobre la información y las operaciones de Aurora Market.
3. Proponer Medidas de Mitigación y recomendaciones de seguridad para las vulnerabilidades identificadas priorizando aquello que representa un mayor riesgo para Aurora Market.

Alcance

*** Si se Evaluara:**

Aurora Market solo indico que se evaluará únicamente la aplicación Web.
Las Funcionalidades accesibles para los Usuarios y los mecanismos de Autenticación y control de acceso asociados a la aplicación.

*** Fuera del Alcance:**

Sistemas o servidores internos que no hayan sido expresamente autorizados.

Equipos Personales o Corporativos de los Empleados.

Correos Electrónicos y otros servicios corporativos ajenos a la Aplicación evaluada.

Cualquier Infraestructura o Activo de terceros que no forme parte de Aurora Market.

Autorización y Condiciones

*** Permisos Requeridos:**

Antes de iniciar el Pentest se debe contar con una autorización Formal por escrito de Aurora Market en la que se establezca el Alcance, las actividades permitidas, las restricciones y las condiciones de Evaluación.

*** Condiciones Acordadas:**

No interrumpir el servicio ni afectar la disponibilidad de la aplicación.

No modificar ni eliminar información real de los clientes.

Realizar las pruebas preferiblemente en horarios de menor actividad para reducir el impacto sobre las operaciones.

Comunicar inmediatamente a Aurora Market cualquier vulnerabilidad o hallazgo crítico identificado.

Tipo de Pentest.

Gray-Box:

Ya que el equipo dispone de información limitada sobre el entorno de Aurora Market. Solo se conoce la existencia de la aplicación Web, la base de Datos y un mecanismo de autenticación y diferentes tipos de usuarios pero no cuenta con todos los detalles técnicos de infraestructura.

Planificacion

*** Objetivo:**

Evaluar la Seguridad de la aplicación Web Aurora Market mediante la identificación de Vulnerabilidades, el análisis de los riesgos asociados y la propuesta de medidas de Mitigación.

*** Alcance:**

La evaluación se limitará exclusivamente a la aplicación Web y a los componentes expresamente autorizados por Aurora Market, cualquier sistema o servicio no autorizado quedará fuera del alcance.

*** Permisos y condiciones:**

se contará con una autorización Formal antes de iniciar las pruebas. Se respetan las condiciones establecidas por Aurora Market de no interrumpir el servicio, no modificar ni eliminar la información real de los clientes, evitar afectar la disponibilidad y comunicar inmediatamente cualquier hallazgo crítico.

*** Metodologia:**

se seguirá una metodología estructurada de pentesting como OWASP que permitirá realizar la evaluación de forma organizada y sistemática facilitando la identificación, análisis y documentación de las vulnerabilidades encontradas. OWASP WSTG es la más indicada para analizar esta aplicación Web.

*** Recopilacion de informacion Previa:**

Se analizará la información disponible sobre la aplicación Web para comprender su funcionamiento, identificar posibles áreas de interés y estructurar las pruebas necesarias para cumplir los objetivos establecidos.

*** Recursos Necesarios:**

Se requerirá un equipo de trabajo, Herramientas de análisis de seguridad como Burp suite, OWASP ZAP y Nmap, un acceso autorizado y cuentas de pruebas proporcionadas por Aurora Market, documentación de autorización Formal,

alcance y tiempo para realizar las pruebas y un canal de comunicación con la Empresa.

*** Programación del Pentest:**

Se establecen previamente la duración y horarios de las pruebas Aurora Market hace énfasis en que sea en un horario de menor actividad para minimizar impactos sobre las operaciones y sus usuarios.

Fases del Pentest.

*** Reconocimiento:**

Se recopila información sobre la aplicación Web de Aurora Market para conocer el entorno, identificar funcionalidad y posibles puntos de entrada, siempre respetando el alcance establecido.

*** Análisis de Vulnerabilidades:**

Se analizan los componentes y funcionalidades identificadas durante el reconocimiento para detectar posibles debilidades de seguridad que pueden representar un riesgo para Aurora Market. Revisamos autenticación, controles de acceso, configuraciones expuestas de la aplicación siempre dentro del alcance establecido.

*** Explotacion:**

Aquí se comprueba de forma controlada si las vulnerabilidades identificadas pueden ser explotadas respetando en todo momento el alcance y las condiciones establecidas por Aurora Market sin modificar información real y sin interrumpir el servicio ni afectar la disponibilidad de la aplicación.

*** Post- Explotacion:**

Se analizará el nivel de acceso obtenido y el posible impacto de las vulnerabilidades explotadas respetando el límite establecido sin afectar las operaciones de la organización.

*** Informe:**

Se documentaran las vulnerabilidades identificadas las evidencias obtenidas, su nivel de riesgo e impacto así como las recomendaciones para su mitigación. Este informe servirá como registro de la evaluación realizada y permitirá al equipo de Aurora Market tomar las medidas necesarias para mejorar la seguridad de la aplicación.

Investigacion.

Aquí debemos usar una metodología que nos proporcione una estructura para saber qué áreas revisar y cómo organizar las pruebas evitando trabajar de manera improvisada.

Para este Caso de Aurora Market usaremos OWASP web security testing Guide (WSTG) la cual resulta ser la más adecuada para este proyecto porque la aplicación Web es el objetivo principal de la evaluación y nos permite realizar pruebas de manera estructurada, sistemática y ordenada abarcando diferentes áreas de seguridad como autenticación, autorización, gestión de sesiones y validación de entradas.

Su utilización ayudará a organizar las pruebas, reducir la posibilidad de omitir aspectos importantes y documentar adecuadamente los hallazgos obtenidos durante el Pentest.